



Formation Kubernetes

Session 6 — Secrets Avancés : ESO et Vault

Reflekt Lab | 22h de formation | 11 sessions

Agenda de la session



Recap — Secrets S5

K8s Secrets, base64, CSI Secret Store, problèmes de sécurité

5 min



External Secrets Operator

Architecture ESO, SecretStore, auto-sync vers GCP

15 min



SecretStore & ExternalSecret

Anatomie des ressources, mapping de secrets

10 min



Refresh automatique

Périodicité, détection de changements, pod reload

8 min



HashiCorp Vault

Architecture, use-cases, Vault Agent Injector, quand l'utiliser

12 min



Démo live RFLKT

Module external_secrets en prod, Workload Identity

8 min

Recap — Session 5



K8s Secrets

Stockage dans etcd, base64 = encodage (pas chiffrement)



CSI Secret Store

Provider : GCP, AWS, Azure — accès au provider natif sans sync K8s



Chiffrement etcd

Activation optionnelle : `--encryption-provider-config`

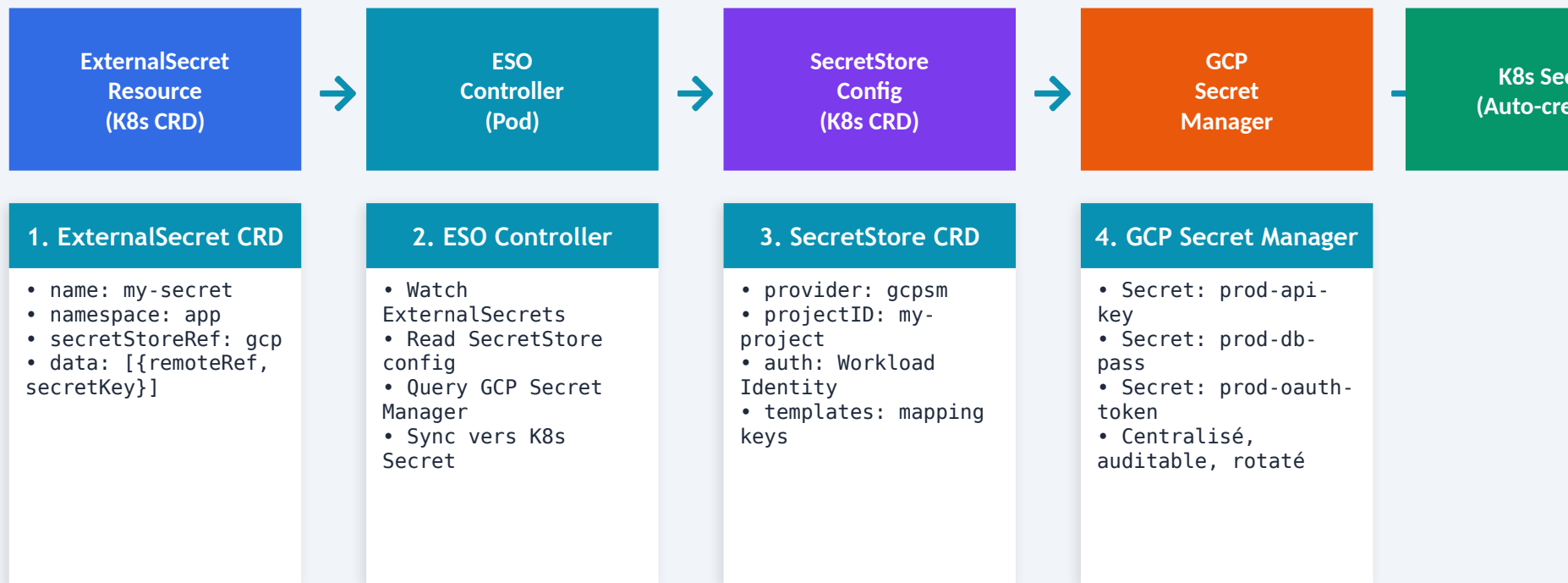


Problèmes S5

Secrets en clair dans etcd, gestion manuelle, pas de rotation auto

Session 6 : Automatiser la synchronisation et la rotation des secrets

External Secrets Operator – Architecture



SecretStore & ExternalSecret — Anatomie

```
apiVersion: external-secrets.io/v1beta1
kind: SecretStore
metadata:
  name: gcp-secret-store
  namespace: exercices
spec:
  provider:
    gcpsm:
      projectID: my-gcp-project
      auth:
        workloadIdentity:
          clusterLocation: europe-west9
          clusterName: my-cluster
          serviceAccountRef:
            name: eso-sa
```

projectID : GCP project où vivent les secrets

Workload Identity : auth sans clé API

```
apiVersion: external-secrets.io/v1beta1
kind: ExternalSecret
metadata:
  name: prod-api-secret
spec:
  refreshInterval: 1h
  secretStoreRef:
    name: gcp-secret-store
  target:
    name: api-credentials
  creationPolicy: Owner
  data:
    - secretKey: API_KEY
      remoteRef:
        key: prod-api-key
```

refreshInterval : resync toutes les 1h (default)

remoteRef ↔ secretKey : mapping GCP → K8s Secret

Refresh automatique – Auto-sync de GCP vers K8s

T=0



Changement secret dans GCP

T+5s



ESO detect (watch ou polling)

T+10s



K8s Secret mis à jour

T+15s



Pod recharge env vars (si déploiement rolling restart)

T+20s



App utilise le nouveau secret

refreshInterval: 1h (défaut) | Min: 15s, Recommended: 1h+

Plus court = charge GCP ↑ , coût ↑ | Plus long = delay de rotation ↑

CSI Secret Store vs External Secrets Operator

Critère	CSI Secret Store	External Secrets Operator
Stockage	Aucun (volume mount direct)	K8s Secret (etcd)
Sync	Au mount du pod (lancement)	Périodique (1h défaut)
Env vars	Non (fichier uniquement)	Oui (K8s Secret → env)
Pod reload	Auto (fichier change)	Manuel (restart deploy)
Coût	Faible (1 API call / pod start)	Moyen (1 call / interval)
Compliance	Zéro trace K8s Secret	Trace dans etcd (chiffrer !)
Use-case	Fichiers config, certs	Env vars, rotation auto

Règle d'or : CSI pour fichiers, ESO pour env vars + rotation auto

HashiCorp Vault – Architecture & Use-cases

Vault Server

- Storage : Raft intégré (défaut) ou Consul/S3/GCS
- Secret engines : KV, PKI, SSH, DB
- Auth methods : Kubernetes, JWT, LDAP
- Policies : RBAC fine-grained

Intégration K8s

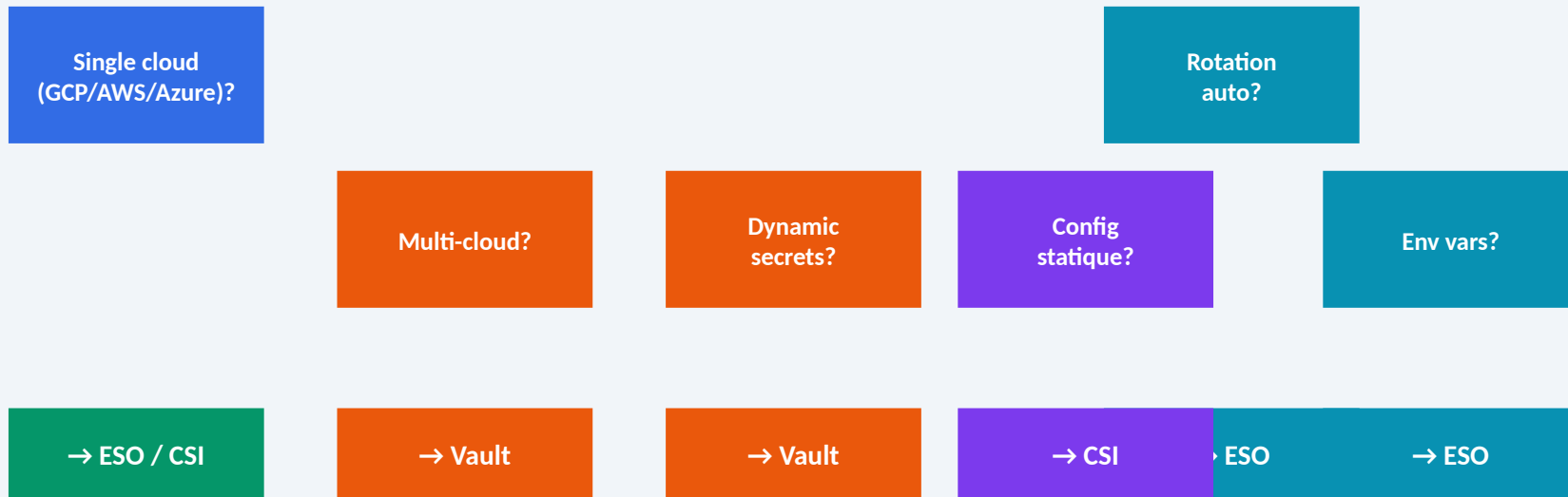
- Vault Secrets Operator (VSO) — CRD natif, recommandé
- Vault Agent Injector — sidecar via webhook (legacy)
- Auto-renew token + rotation
- Secret template rendering

Dynamic Secrets

- Credentials générées à la demande
- TTL court (ex: 1h)
- Auto-revoke : plus besoin de rotation
- Audit complet : qui a généré quoi

Vault = Gestionnaire de secrets centralisé pour toute l'infrastructure (pas juste K8s)

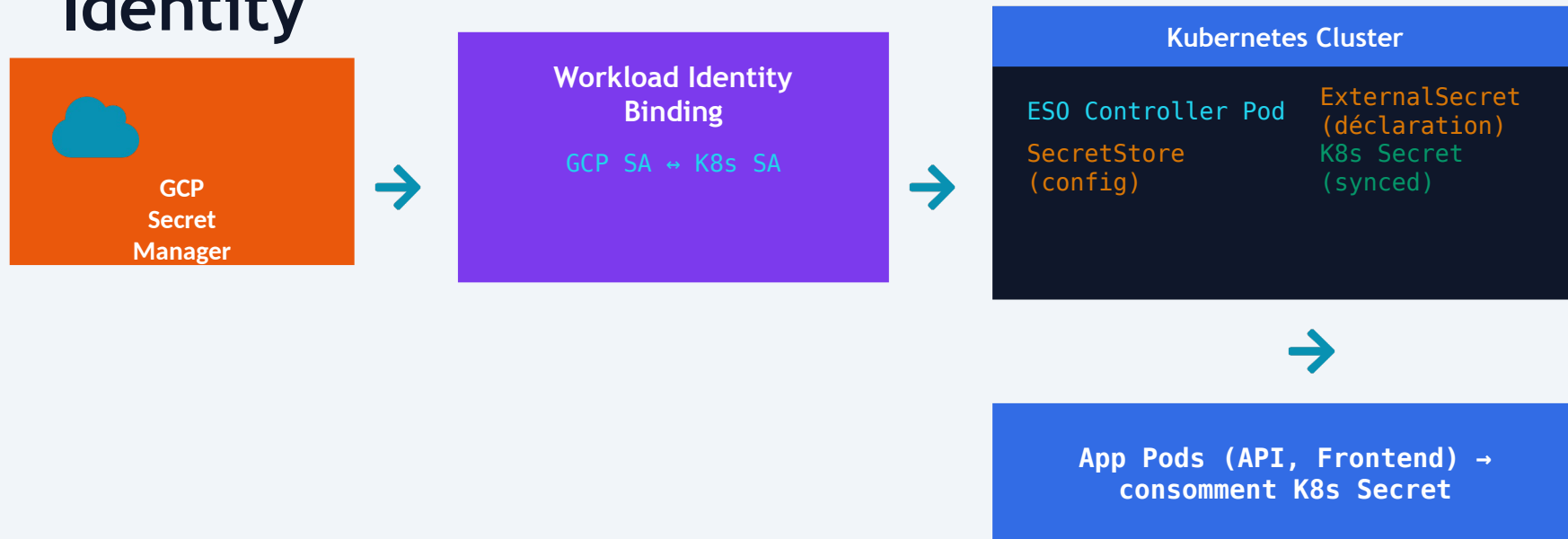
Matrice de décision : Quel tool choisir ?



CSI = Fichiers, pas de pod reload | **ESO** = Env vars, rotation auto simple | **Vault** = Secrets dynamiques, multi-cloud, compliance strict

RFLKT utilise principalement ESO (simple + efficace pour notre cas). Vault serait nécessaire si on était multi-cloud.

Architecture du TP – ESO avec Workload Identity



Étapes du TP

1. Installer ESO via Helm
2. Configurer Workload Identity binding (GCP SA ↔ K8s SA)
3. Créer SecretStore avec projectID et auth
4. Créer ExternalSecret qui pointe au SecretStore
5. Vérifier : K8s Secret créé, pods reçoivent env vars, modifier secret GCP → resync auto

Démo live — External Secrets en production

Infrastructure RFLKT — Module `external_secrets/`

`modules/external_secrets/`

Helm install ESO, version, values avec `refreshInterval`

SecretStore déclarative

Pour chaque provider (gcpsm, vault), config via Terraform

ExternalSecrets auto-générées

Via locals pour chaque secret (prod-api-key, staging-oauth-token)

Workload Identity

GKE-spécifique : KMS keys binding, IAM roles pour ESO pod

"Chaque app RFLKT a ses secrets auto-synced. Les rotations en GCP se propagent en < 1h dans les pods"

Pièges et bonnes pratiques ESO/Vault

refreshInterval trop court

Requêtes fréquentes à GCP = dépassement quota + coût API. Min 15s, recommandé 1h+

Solution :

Ajuster selon la criticité : 1h pour config, 15m pour API key sensible

Pod ne recharge pas secret

K8s Secret mis à jour mais le pod a la vieille valeur en mémoire (env vars statiques)

Solution :

Faire un rolling restart : `kubectl rollout restart deployment/api`

SecretStore non-trouvée

ExternalSecret en namespace A pointe à SecretStore en namespace B → erreur silencieuse

Solution :

SecretStore et ExternalSecret même namespace, ou utiliser ClusterSecretStore

Workload Identity binding oubliée

ESO pod peut pas requête GCP (permission denied), secret reste manquant

Solution :

Vérifier : `kubectl describe pod ESO-POD | grep gcp-service-account`



Récap & Mini-défi



ESO : Sync automatique des secrets GCP → K8s Secret



RefreshInterval : rotation auto-périodique sans intervention



SecretStore : config du provider (GCP, Vault, AWS...)



ExternalSecret : déclaration des secrets à syncer + mapping

Mini-défi pour la prochaine session

1. Recherchez 3 use-cases où Vault est meilleur que ESO/CSI
(Multi-cloud ? Dynamic secrets ? Compliance ? SSH certs ?)
2. Imaginez une architecture Vault pour gérer secrets de 3 datacenters différents
3. Répondez : dans notre cas RFLKT (single cloud), pourquoi ESO est-elle bonne ?